TryHackMe Walkthrough: OpenVAS

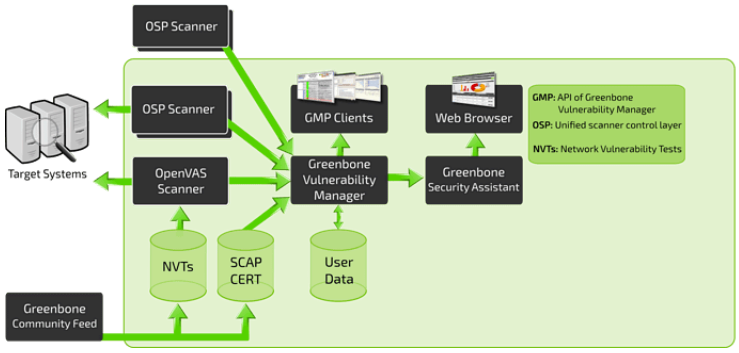
OpenVAS, an application used to scan endpoints and web applications to identify and detect vulnerabilities. It is commonly used by corporations as part of their mitigation solutions to quickly identify any gaps in their production or even development servers or applications. This is not an end all be all solution but can help to get rid of any common vulnerabilities that may have slipped through the cracks.

From the OpenVAS GitHub repository "This is the Open Vulnerability Assessment Scanner (OpenVAS) of the Greenbone Vulnerability Management (GVM) Solution. It is used for the Greenbone Security Manager appliances and is a full-featured scan engine that executes a continuously updated and extended feed of Network Vulnerability Tests (NVTs)."

GVM Framework Architecture

As previously mentioned OpenVAS is built off the GreenBone Vulnerability Management (GVM) solution and is only one of the appliances that is released from GreenBone.

OpenVAS is a service within a larger framework of services known as Greenbone Vulnerability Management (GVM). In this task we will break down the services that make up the framework and their roles.



Above is a brief visual breakdown of what the GVM framework looks like. There are many components that are a part of the architecture for the GVM framework, but we can break it down into three distinct sections: Front-End, Back-End, and Vulnerability/Information feed. These sections are further explained below.

Vulnerability/Information Feed (NVT, SCAP CERT, User Data, Community Feed)

This section will contain all information and vulnerability tests that come from the Greenbone Community Feed that will be the main baseline for testing against systems. This can also include User Data provided by the user in place of Greenbone NVTs and SCAP CERTs.

Back-End (OSP, OpenVAS, Targets)

The back-end infrastructure is what will be actually conducting all of the vulnerability scanning and processing data and NVTS through OpenVAS and GVM. Greenbone Vulnerability Manager will be the middle man between the scanners and the front-end user interfaces.

Front-End (GSA, Web Interfaces)

This is what you interact with when you navigate to OpenVAS in your browser. The web interfaces are built off of the Greenbone Security Assistant and make life easier for an analyst or operator when working with OpenVAS or other forms of scanners through the GVM.

For more information about the GVM framework architecture check out this forum post https://community.greenbone.net/t/about-gvm-10-architecture/1231

Installing VAS

Note: OpenVAS is not meant to be installed on the AttackBox.

The installation procedure for OpenVAS can vary based on how you decide to install. You can install from Kali/OpenVAS repos, install from source, or run from a docker container. For our purposes, the preferred method is to run it inside a docker container as we don't have to worry about a lot of the setup or errors that we may run into with other installation methods.

Option 1: Install from Kali/OpenVAS repositories

Installing from repositories can sometimes be very simple or it can be a very painful process. For OpenVAS, the installation ranges in difficulty and can require many configurations ran. For more information about this option check out the guides below.

https://websiteforstudents.com/how-to-install-and-configure-openvas-on-ubuntu-18-04-16-04/

(opens in new tab)

(opens in new tab)

https://www.agix.com.au/installing-openvas-on-kali-in-2020/

(opens in new tab)

Option 2: Install from Source

Installing from source is the least preferred option for beginners and the least optimized way of installing OpenVAS due to prerequisites and make errors. For more information about installing from source look at the INSTALL.MD

(opens in new tab)

.

Option 3: Run from Docker (Preferred)

Docker is by far the easiest of all three installation methods and only requires one command to be run to get the client started. For this installation procedure, you will need docker installed.

For more information about this information procedure checkout the openvas-docker project on GitHub

(opens in new tab)

and DockerHub

(opens in new tab)

.

1. `apt install docker.io`

2. `docker run -d -p 443:443 --name openvas mikesplain/openvas`

```
cryillic@ubuntu:~$ sudo docker run -d -p 443:443 --name openvas mikesplain/openvas
Unable to find image 'mikesplain/openvas:latest' locally
latest: Pulling from mikesplain/openvas
34667c7e4631: Pull complete
d18d76a881a4: Pull complete
119c7358fbfc: Pull complete
2aaf13f3eff0: Pull complete
67b182362ac2: Pull complete
c878d3d5e895: Pull complete
ec12cc49fe18: Pull complete
c4c454aeebef: Pull complete
27d3410150b2: Pull complete
e08d578dc278: Pull complete
44951337cd32: Pull complete
8c7fe885e62a: Pull complete
a4f833680e45: Pull complete
Digest: sha256:23c8412b5f9f370ba71e5cd3db36e6f2e269666cd8a3e3e7872f20f8063b2752
Status: Downloaded newer image for mikesplain/openvas:latest
6b4bb110fa6e5aafc387a74df4be632f97ed1125ea1f525ebdc4d9fe44c1d717
```

This command will both pull the docker container and then run the container. It may take a few minutes for the container to fully set up and begin running. Once it is complete you can then navigate to https://127.0.0.1 in your preferred browser and OpenVAS will be set up and ready to go!

Below are the default credentials to access OpenVAS/GVM:

Username: `admin`

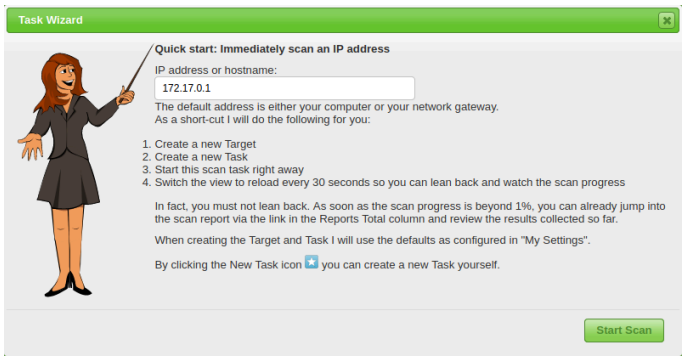
Password: `admin`

If you successfully logged into OpenVAS you should see a dashboard that looks similar to the one below.

Initial Configuration

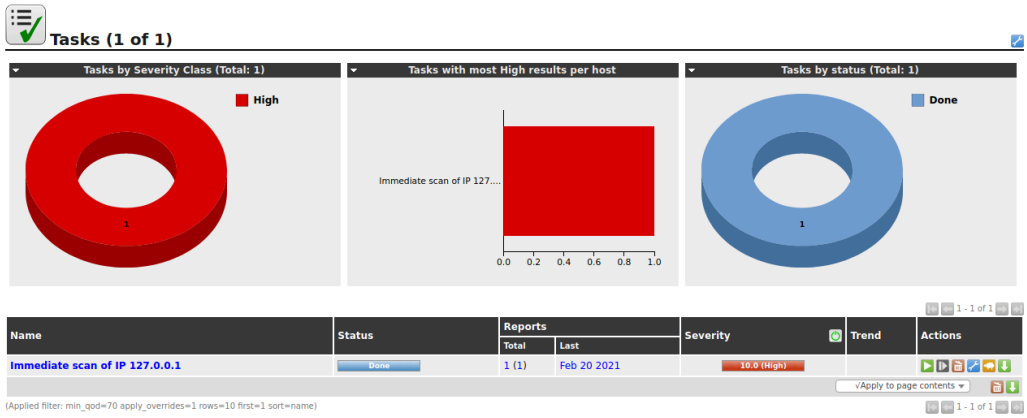
Before we can start scanning and implementing OpenVAS into our vulnerability management solution we need to do a little bit of maintenance and configuration to get OpenVAS properly working. Luckily for us, OpenVAS makes the process very easy and includes a wizard to make the process straightforward.

Begin by navigating to *Scans* > *Tasks* and clicking on the purple magic wand icon to begin the basic configuration wizard. We recommend beginning a scan on `127.0.0.1` to test out your installation and ensure it is working properly.



If you successfully navigated to the wizard you should see a pop-up similar to the one above. This is where you will set up your initial scan against your localhost to ensure everything is properly configured.

The scan may take a while to complete, allow OpenVAS enough time to finish the scan, and then you will be met with a new dashboard for monitoring and analyzing your complete and ongoing scans like the one below.



Once your scan has finished you can navigate to *Scans* > *Reports* and click on your newly created report from your previous task.

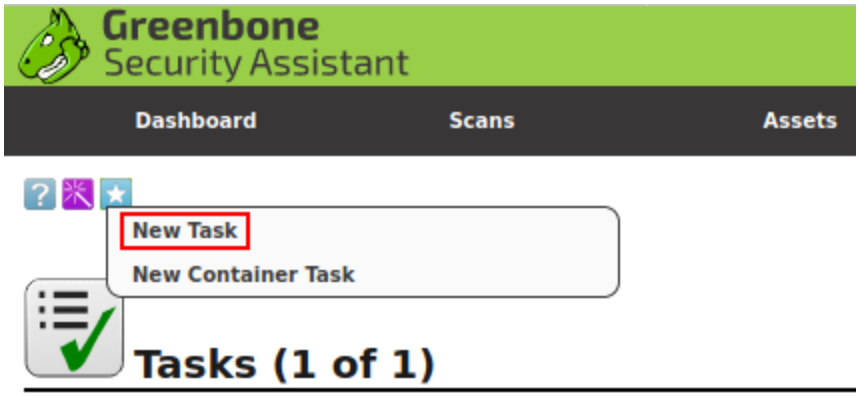
If correctly configured you should see three different vulnerabilities reported all originating from OpenVAS itself. This is normal behavior and can be configured/changed to maintain your OpSec.

Scan Infrastructure

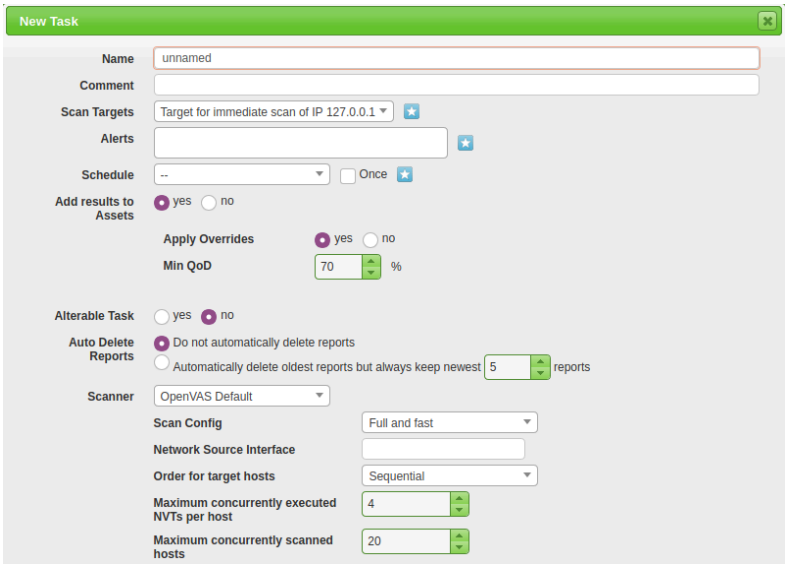
Now that we know that everything is working we can get into the nitty-gritty of OpenVAS and how it works. Deploy the machine and navigate to *Scans* > *Tasks* to begin creating a task to scan the provided machine.

Creating a Task

To create a configurable task navigate to the star icon in the upper right-hand corner of the *Tasks* dashboard and select *New Task*.



Once you select New Task from the dropdown you will be met with a large pop-up with many options. We will break down each of the options sections and what they can be used for.



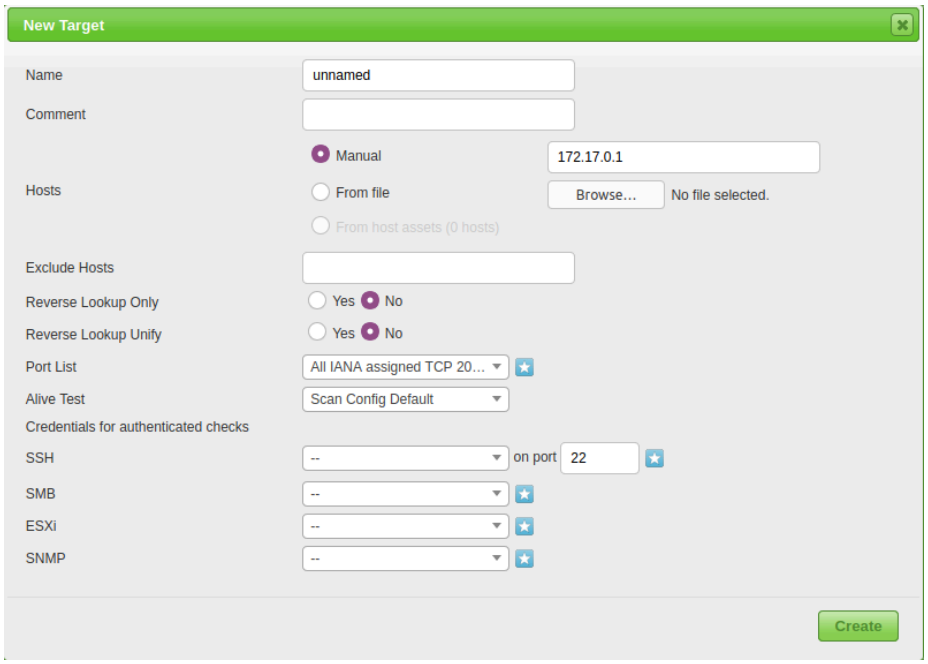
For this task, we will be focusing only on the Name, Scan Targets, and Scanner Type, and Scan Config. In later tasks, we will be focusing on the other options for more advanced configuration and implementation/automation.

1. Name: Allows us to set the name the scan will be known as inside of OpenVAS
2. Scan Targets: The targets to scan, can include Hosts, Ports, and Credentials. To create a new target you will need to follow another pop-up, this will be covered later in this task.
3. Scanner: The scanner to use by default will use the OpenVAS architecture however you can set this to any scanner of your choosing in the settings menu.

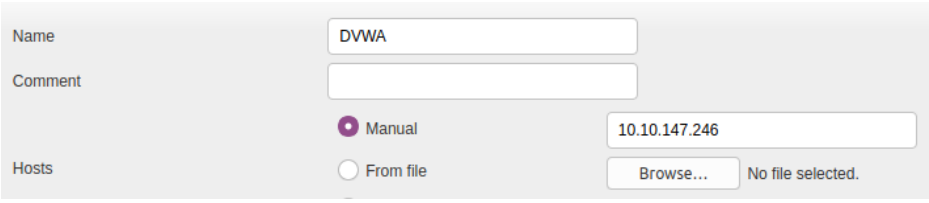
4. Scan Config: OpenVAS has seven different scan types you can select from and will be used based on how you aggressive or what information you want to collect from your scan.

Scoping a New Target

To scope a new target, navigate to the star icon next to *Scan Targets*.

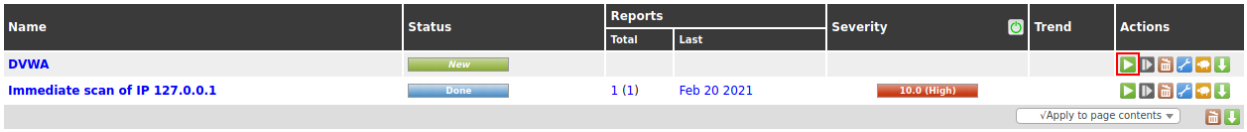


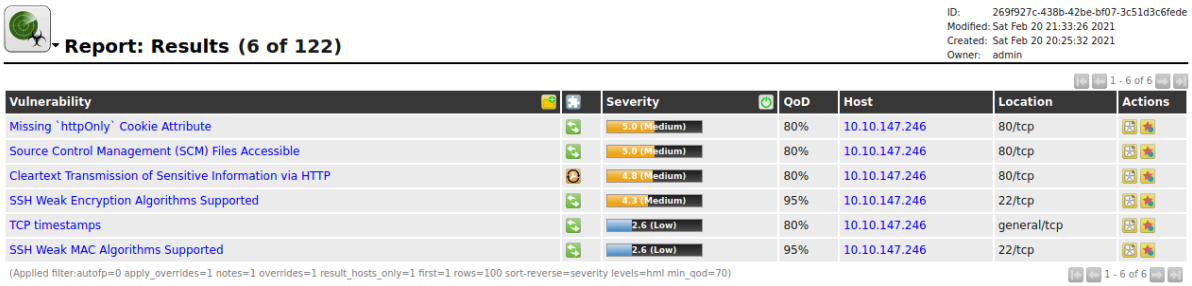
Above is the menu for configuring a new target. The two main options you will need to configure are the Name and the Hosts. This procedure is fairly straightforward and other options will only be used in advanced vulnerability management solutions. These will be covered in later tasks.



Now that we have our target scoped we can continue to create our task and begin the scan.

Once you create the task you will be brought back to the scan dashboard where you can monitor and start your task. To start the task navigate to the start icon under *Actions*.





Reporting and Continuous Monitoring

OpenVAS has very strong reporting and monitoring capabilities that can contribute to an efficient and optimal solution in your build or vulnerability management pipeline.

Download the provided report from a vulnerable machine to get familiar with the automated reporting capabilities of OpenVAS.

Breaking Down the Report

The automated report from OpenVAS begins with some basic host and task information including Host, Start, End, and Vulnerability categories. It will also check for host authentications and an overall summary of open ports on the host.

Host Summary

Host	Start	End	High	Medium	Low	Log	False Positive
192.168.1.98	Feb 21, 18:20:54	Feb 21, 18:42:56	9	28	2	0	0
Total: 1			9	28	2	0	0

Host Authentications

Host	Protocol	Result	Port/User
192.168.1.98	SMB	Success	Protocol SMB, Port 445, User

Results per Host

Host 192.168.1.98

Scanning of this host started at: Sun Feb 21 18:20:54 2021 UTC
Number of results: 39

Port Summary for Host 192.168.1.98

Service (Port)	Threat Level
80/tcp	High
5432/tcp	High
22/tcp	High
25/tcp	Medium
3306/tcp	High
general/tcp	High
23/tcp	Medium
3632/tcp	High

After the basic host and task information OpenVAS will report on each of the vulnerabilities found.

High (CVSS: 10.0)
NVT: OS End Of Life Detection (OID: 1.3.6.1.4.1.25623.1.0.103674)

Product detection result: cpe:/o:canonical:ubuntu_linux:8.04 by OS Detection Consolidation and Reporting (OID: 1.3.6.1.4.1.25623.1.0.105937)

Summary

OS End Of Life Detection

The Operating System on the remote host has reached the end of life and should not be used anymore.

Vulnerability Detection Result

```
The "Ubuntu" Operating System on the remote host has reached the end of life.

CPE:                cpe:/o:canonical:ubuntu_linux:8.04
Installed version,
build or SP:        8.04
EOL date:           2013-05-09
EOL info:           https://wiki.ubuntu.com/Releases
```

Solution

Solution type: Mitigation

Vulnerability Detection Method

Details: OS End Of Life Detection (OID: 1.3.6.1.4.1.25623.1.0.103674)

Version used: $Revision: 8927 $

Product Detection Result

Product: cpe:/o:canonical:ubuntu_linux:8.04
Method: OS Detection Consolidation and Reporting (OID: 1.3.6.1.4.1.25623.1.0.105937)

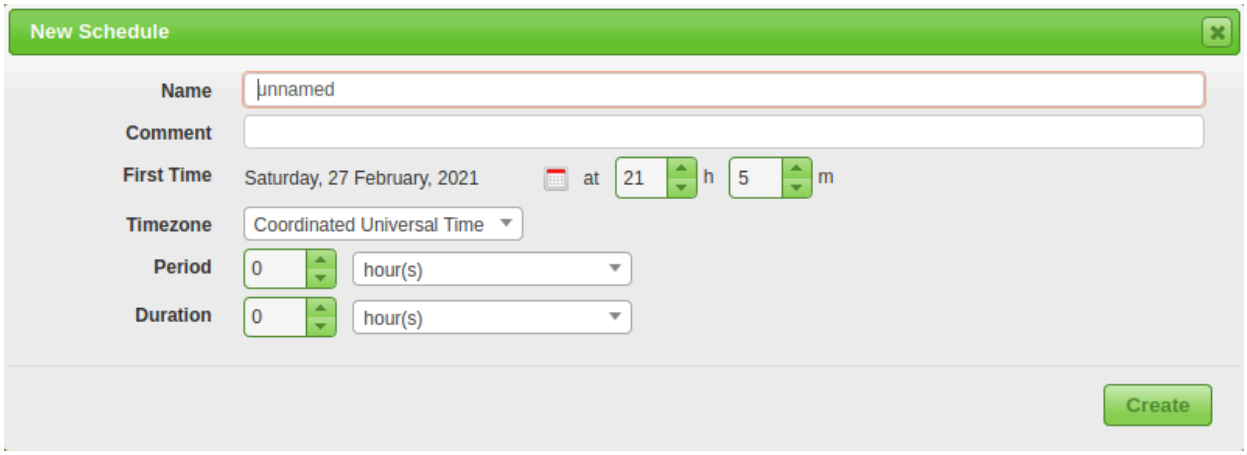
In the above image, the vulnerability breakdown can give a lot of information. We can gather a summary of the vulnerability, detection details, mitigation details, and method of detection.

Continuous Monitoring Overview

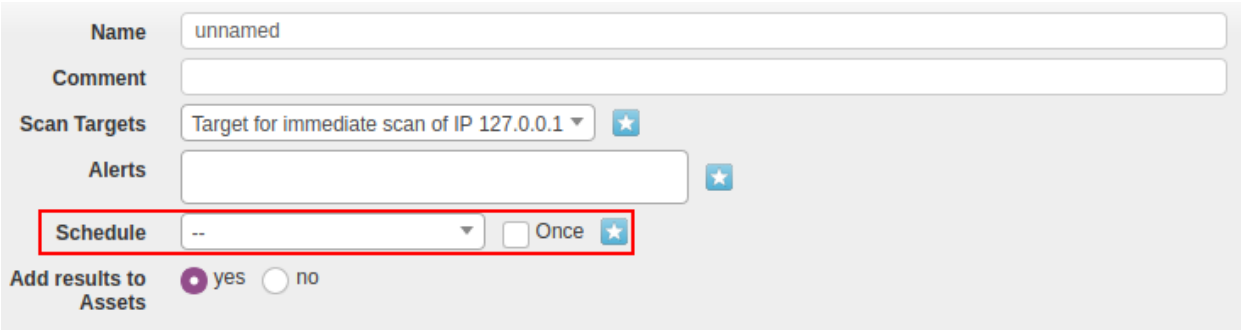
OpenVAS offers many options for continuous and scheduled monitoring/vulnerability management. If you work in a team or a pipeline this can allow you to efficiently and quickly optimize your current solutions. Examples of continuous vulnerability scanning utilities are Alerts, Schedules, and Agents. Agents are out of scope for this room but we will be covering the configuration of schedules and alerts below.

Creating Schedules

To begin creating a schedule navigate to *Configuration* > *Schedules* and as always click on the blue star icon in the upper left-hand corner. You should see a pop-up similar to the one below.

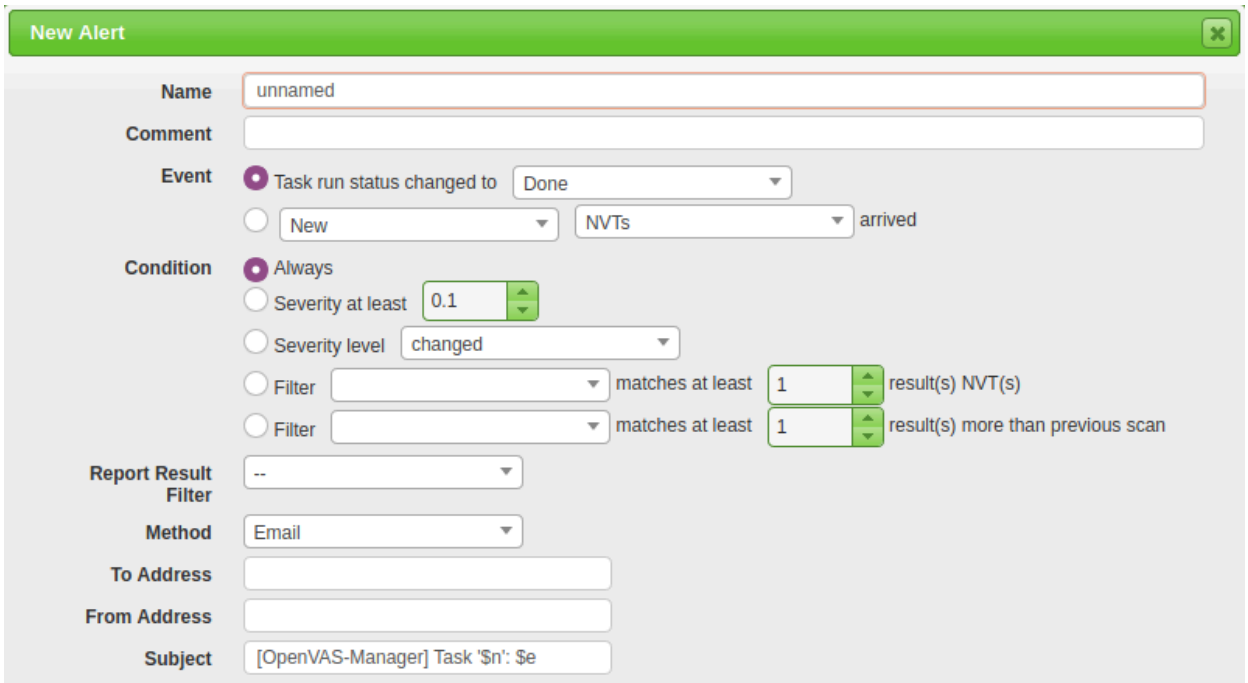


Fill out the basic information like Name, First Start Time, Period, etc. Once you have the schedule created you can now create a new Task/Scan with this created schedule attached. You can see this option below.

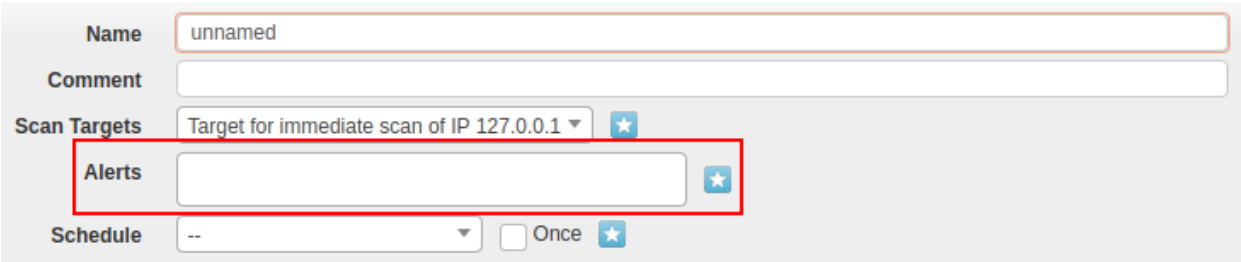


Crafting Alerts

The process for creating alerts is very similar to creating a schedule, navigate to *Configuration* > *Alerts* and click on the blue star icon in the upper left-hand corner. You should see a pop-up similar to the one below.



You will notice that there are a lot more options than the schedule menu, don't let this intimidate you, the process is very similar and straightforward. The main options you will need to worry about are Name, Event, Condition, and To Address. The event can be configured to alert based on the status of the scan or when a new NVT/vulnerability is detected. The condition option will make sure that your inbox isn't flooded with alerts, this can be changed based on severity or filters. The To Address is fairly self-explanatory and will send an email of the alert to the specified mail address. Once created you will again need to connect the alert to a new Task/Scan. You can see the specific option below.



Case 001: MS00-What?

The OpenVAS reports used are created from rooms on TryHackMe, machines used are credited to their respective owners.

Host Summary

Host	Start	End	High	Medium	Low	Log	False Positive
10.10.148.71	Feb 28, 00:04:46	Feb 28, 00:21:02	1	3	1	0	0
Total: 1			1	3	1	0	0

Results per Host

Host 10.10.148.71

Scanning of this host started at:	Sun Feb 28 00:04:46 2021 UTC
Number of results:	5

Port Summary for Host 10.10.148.71

Service (Port)	Threat Level
3389/tcp	Medium
135/tcp	Medium
general/tcp	Low

445/tcp	High

Security Issues for Host 10.10.148.71

445/tcp

High (CVSS: 9.3)

NVT: Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389) (OID: 1.3.6.1.4.1.25623.1.0.810676)

Summary

This host is missing a critical security update according to Microsoft Bulletin MS17-010.

Vulnerability Detection Result

Vulnerability was detected according to the Vulnerability Detection Method.

Impact

Successful exploitation will allow remote attackers to gain the ability to execute code on the target server, also could lead to information disclosure from the server.

Solution

Solution type: VendorFix

Run Windows Update and update the listed hotfixes or download and update mentioned hotfixes in the advisory

Affected Software/OS

Microsoft Windows 10 x32/x64 Edition Microsoft Windows Server 2012 Edition Microsoft Windows Server 2016 Microsoft Windows 8.1 x32/x64 Edition Microsoft Windows Server 2012 R2 Edition Microsoft Windows 7 x32/x64 Edition Service Pack 1 Microsoft Windows Vista x32/x64 Edition Service Pack 2 Microsoft Windows Server 2008 R2 x64 Edition Service Pack 1 Microsoft Windows Server 2008 x32/x64 Edition Service Pack 2

Vulnerability Insight

Multiple flaws exist due to the way that the Microsoft Server Message Block 1.0 (SMBv1) server handles certain requests.

Vulnerability Detection Method

Send the crafted SMB transaction request with fid = 0 and check the response to confirm the vulnerability.

Details: Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389) (OID: 1.3.6.1.4.1.25623.1.0.810676)

Version used: $Revision: 11874 $

References

CVE: CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0147, CVE-2017-0148

BID: 96703, 96704, 96705, 96707, 96709, 96706

CERT: CB-K17/0435, DFN-CERT-2017-0448

Other: https://support.microsoft.com/en-in/kb/4013078

https://technet.microsoft.com/library/security/MS17-010

https://github.com/rapid7/metasploit-framework/pull/8167/files

135/tcp

Medium (CVSS: 5.0)

NVT: DCE/RPC and MSRPC Services Enumeration Reporting (OID: 1.3.6.1.4.1.25623.1.0.10736)

Summary

Distributed Computing Environment / Remote Procedure Calls (DCE/RPC) or MSRPC services running on the remote host can be enumerated by connecting on port 135 and doing the appropriate queries.

Vulnerability Detection Result

Here is the list of DCE/RPC or MSRPC services running on this host via the TCP protocol:

Port: 49152/tcp

UUID: d95afe70-a6d5-4259-822e-2c84da1ddb0d, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49152]

Port: 49153/tcp

UUID: 06bba54a-be05-49f9-b0a0-30f790261023, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49153]

Annotation: Security Center

UUID: 30adc50c-5cbc-46ce-9a0e-91914789e23c, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49153]

Annotation: NRP server endpoint

UUID: 3c4728c5-f0ab-448b-bda1-6ce01eb0a6d5, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49153]

Annotation: DHCP Client LRPC Endpoint

UUID: 3c4728c5-f0ab-448b-bda1-6ce01eb0a6d6, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49153]

Annotation: DHCPv6 Client LRPC Endpoint

UUID: f6beaff7-1e19-4fbb-9f8f-b89e2018337c, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49153]

Annotation: Event log TCPIP

Port: 49154/tcp

UUID: 30b044a5-a225-43f0-b3a4-e060df91f9c1, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49154]

UUID: 552d076a-cb29-4e44-8b6a-d15e59e2c0af, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49154]

Annotation: IP Transition Configuration endpoint

UUID: 86d35949-83c9-4044-b424-db363231fd0c, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49154]

UUID: 98716d03-89ac-44c7-bb8c-285824e51c4a, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49154]

Annotation: XactSrv service

UUID: a398e520-d59a-4bdd-aa7a-3c1e0303a511, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49154]

Annotation: IKE/Authip API

UUID: c9ac6db5-82b7-4e55-ae8a-e464ed7b4277, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49154]

Annotation: Impl friendly name

Port: 49158/tcp

UUID: 367abb81-9844-35f1-ad32-98f038001003, version 2

Endpoint: ncacn_ip_tcp:10.10.148.71[49158]

Port: 49160/tcp

UUID: 12345778-1234-abcd-ef00-0123456789ac, version 1

Endpoint: ncacn_ip_tcp:10.10.148.71[49160]

Named pipe : lsass

Win32 service or process : lsass.exe

Description : SAM access

Note: DCE/RPC or MSRPC services running on this host locally were identified. Reporting this list is not enabled by default due to the possible large size of this list. See the script preferences to enable this reporting.

Impact

An attacker may use this fact to gain more knowledge about the remote host.

Solution

Solution type: Mitigation

Filter incoming traffic to this ports.

Vulnerability Detection Method

Details: DCE/RPC and MSRPC Services Enumeration Reporting (OID: 1.3.6.1.4.1.25623.1.0.10736)

Version used: $Revision: 6319 $

3389/tcp

Medium (CVSS: 4.3)

NVT: SSL/TLS: Report Weak Cipher Suites (OID: 1.3.6.1.4.1.25623.1.0.103440)

Summary

This routine reports all Weak SSL/TLS cipher suites accepted by a service.

NOTE: No severity for SMTP services with 'Opportunistic TLS' and weak cipher suites on port 25/tcp is reported. If too strong cipher suites are configured for this service the alternative would be to fall back to an even more insecure cleartext communication.

Vulnerability Detection Result

'Weak' cipher suites accepted by this service via the TLSv1.0 protocol:

TLS_RSA_WITH_RC4_128_MD5

TLS_RSA_WITH_RC4_128_SHA

Solution

Solution type: Mitigation

The configuration of this services should be changed so that it does not accept the listed weak cipher suites anymore.

Please see the references for more resources supporting you with this task.

Vulnerability Insight

These rules are applied for the evaluation of the cryptographic strength:

- RC4 is considered to be weak (CVE-2013-2566, CVE-2015-2808).

- Ciphers using 64 bit or less are considered to be vulnerable to brute force methods and therefore considered as weak (CVE-2015-4000).

- 1024 bit RSA authentication is considered to be insecure and therefore as weak.

- Any cipher considered to be secure for only the next 10 years is considered as medium

- Any other cipher is considered as strong

Vulnerability Detection Method

Details: SSL/TLS: Report Weak Cipher Suites (OID: 1.3.6.1.4.1.25623.1.0.103440)

Version used: $Revision: 11135 $

References

CVE: CVE-2013-2566, CVE-2015-2808, CVE-2015-4000

CERT: CB-K17/1750, CB-K16/1593, CB-K16/1552, CB-K16/1102, CB-K16/0617, CB-K16/0599, CB-K16/0168, CB-K16/0121, CB-K16/0090, CB-K16/0030, CB-K15/1751, CB-K15/1591, CB-K15/1550, CB-K15/1517, CB-K15/1514, CB-K15/1464, CB-K15/1442, CB-K15/1334, CB-K15/1269, CB-K15/1136, CB-K15/1090, CB-K15/1059, CB-K15/1022, CB-K15/1015, CB-K15/0986, CB-K15/0964, CB-K15/0962, CB-K15/0932, CB-K15/0927, CB-K15/0926, CB-K15/0907, CB-K15/0901, CB-K15/0896, CB-K15/0889, CB-K15/0877, CB-K15/0850, CB-K15/0849, CB-K15/0834, CB-K15/0827, CB-K15/0802, CB-K15/0764, CB-K15/0733, CB-K15/0667, CB-K14/0935, CB-K13/0942, DFN-CERT-2017-1821, DFN-CERT-2016-1692, DFN-CERT-2016-1648, DFN-CERT-2016-1168, DFN-CERT-2016-0665, DFN-CERT-2016-0642, DFN-CERT-2016-0184, DFN-CERT-2016-0135, DFN-CERT-2016-0101, DFN-CERT-2016-0035, DFN-CERT-2015-1853, DFN-CERT-2015-1679, DFN-CERT-2015-1632, DFN-CERT-2015-1608, DFN-CERT-2015-1542, DFN-CERT-2015-1518, DFN-CERT-2015-1406, DFN-CERT-2015-1341, DFN-CERT-2015-1194, DFN-CERT-2015-1144, DFN-CERT-2015-1113, DFN-CERT-2015-1078, DFN-CERT-2015-1067, DFN-CERT-2015-1038, DFN-CERT-2015-1016, DFN-CERT-2015-1012, DFN-CERT-2015-0980, DFN-CERT-2015-0977, DFN-CERT-2015-0976, DFN-CERT-2015-0960, DFN-CERT-2015-0956, DFN-CERT-2015-0944, DFN-CERT-2015-0937, DFN-CERT-2015-0925, DFN-CERT-2015-0884, DFN-CERT-2015-0881, DFN-CERT-2015-0879, DFN-CERT-2015-0866, DFN-CERT-2015-0844, DFN-CERT-2015-0800, DFN-CERT-2015-0737, DFN-CERT-2015-0696, DFN-CERT-2014-0977

Other: https://www.bsi.bund.de/SharedDocs/Warnmeldungen/DE/CB/warnmeldung_cb-k16-1465_update_6.html

https://bettercrypto.org/

https://mozilla.github.io/server-side-tls/ssl-config-generator/

3389/tcp

Medium (CVSS: 4.0)

NVT: SSL/TLS: Certificate Signed Using A Weak Signature Algorithm (OID: 1.3.6.1.4.1.25623.1.0.105880)

Summary

The remote service is using a SSL/TLS certificate in the certificate chain that has been signed using a cryptographically weak hashing algorithm.

Vulnerability Detection Result

The following certificates are part of the certificate chain but using insecure signature algorithms:

Subject: CN=Jon-PC

Signature Algorithm: sha1WithRSAEncryption

Solution

Solution type: Mitigation

Servers that use SSL/TLS certificates signed with a weak SHA-1, MD5, MD4 or MD2 hashing algorithm will need to obtain new SHA-2 signed SSL/TLS certificates to avoid web browser SSL/TLS certificate warnings.

Vulnerability Insight

The following hashing algorithms used for signing SSL/TLS certificates are considered cryptographically weak and not secure enough for ongoing use:

- Secure Hash Algorithm 1 (SHA-1)

- Message Digest 5 (MD5)

- Message Digest 4 (MD4)

- Message Digest 2 (MD2)

Beginning as late as January 2017 and as early as June 2016, browser developers such as Microsoft and Google will begin warning users when visiting web sites that use SHA-1 signed Secure Socket Layer (SSL) certificates.

NOTE: The script preference allows to set one or more custom SHA-1 fingerprints of CA certificates which are trusted by this routine. The fingerprints needs to be passed comma-separated and case-insensitive:

Fingerprint1

or

fingerprint1,Fingerprint2

Vulnerability Detection Method

Check which hashing algorithm was used to sign the remote SSL/TLS certificate.

Details: SSL/TLS: Certificate Signed Using A Weak Signature Algorithm (OID: 1.3.6.1.4.1.25623.1.0.105880)

Version used: $Revision: 11524 $

References

Other: https://blog.mozilla.org/security/2014/09/23/phasing-out-certificates-with-sha-1-based-signature-algorithms/

general/tcp

Low (CVSS: 2.6)

NVT: TCP timestamps (OID: 1.3.6.1.4.1.25623.1.0.80091)

Summary

The remote host implements TCP timestamps and therefore allows to compute the uptime.

Vulnerability Detection Result

It was detected that the host implements RFC1323.

The following timestamps were retrieved with a delay of 1 seconds in-between:

Packet 1: 41539

Packet 2: 41668

Impact

A side effect of this feature is that the uptime of the remote host can sometimes be computed.

Solution

Solution type: Mitigation

To disable TCP timestamps on linux add the line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime.

To disable TCP timestamps on Windows execute 'netsh int tcp set global timestamps=disabled'

Starting with Windows Server 2008 and Vista, the timestamp can not be completely disabled.

The default behavior of the TCP/IP stack on this Systems is to not use the Timestamp options when initiating TCP connections, but use them if the TCP peer that is initiating communication includes them in their synchronize (SYN) segment.

See the references for more information.

Affected Software/OS

TCP/IPv4 implementations that implement RFC1323.

Vulnerability Insight

The remote host implements TCP timestamps, as defined by RFC1323.

Vulnerability Detection Method

Special IP packets are forged and sent with a little delay in between to the target IP. The responses are searched for a timestamps. If found, the timestamps are reported.

Details: TCP timestamps (OID: 1.3.6.1.4.1.25623.1.0.80091)

Version used: $Revision: 14310 $

References

Other: http://www.ietf.org/rfc/rfc1323.txt

http://www.microsoft.com/en-us/download/details.aspx?id=9152

In this scenario, you are assigned to a routine vulnerability management pipeline as a SOC analyst. Your automated pipeline has already pulled a scan on the server, it is up to you to analyze and identify risk in this report.

1. When did the scan start in Case 001? **Feb 28, 00:04:46**
2. When did the scan end in Case 001? **Feb 28, 00:21:02**
3. How many ports are open in Case 001? **3**
4. How many total vulnerabilities were found in Case 001? **5**
5. What is the highest severity vulnerability found? (MSxx-xxx) **MS17-010**
6. What is the first affected OS to this vulnerability? **Microsoft Windows 10 x32/x64 Edition**
7. What is the recommended vulnerability detection method? **Send the crafted SMB transaction request with fid = 0 and check the response to confirm the vulnerability.**